MINOR PROJECT – 1 Aashvika Dubey

Cybersecurity Risk Assessment Framework

for Small and Medium Enterprises (SMEs)

Objective: Develop a model for evaluating cybersecurity risks in SMEs and propose mitigation strategies to enhance their security posture.

Step 1: Research Common Cybersecurity Risks in SMEs

1.1 Why SMEs Are High-Risk Targets

Small and medium enterprises are increasingly attractive targets for cybercriminals. Unlike large corporations, SMEs typically lack dedicated IT security teams, operate with limited budgets for security tools, and have employees with minimal cybersecurity awareness. According to industry reports, over 60% of cyberattacks target small businesses, and nearly half of affected SMEs go out of business within six months of a major breach.

1.2 The Three Primary Threat Categories

A. Phishing Attacks

Phishing is the most common attack vector against SMEs. Attackers send fraudulent emails that appear to come from legitimate sources (banks, vendors, or internal HR) to trick employees into revealing login credentials, clicking malicious links, or downloading infected attachments.

- Spear phishing: Highly targeted emails crafted using publicly available employee information
- Business Email Compromise (BEC): Impersonating executives to authorize fraudulent wire transfers
- Smishing/Vishing: Same technique but via SMS or phone calls

Impact: Credential theft, unauthorized system access, financial fraud, data breaches.

B. Ransomware

Ransomware is malicious software that encrypts an organization's files and demands payment (usually in cryptocurrency) for the decryption key. SMEs are prime targets because they often lack proper backup systems and are more likely to pay quickly to restore operations.

- Entry vectors: Phishing emails, unpatched software vulnerabilities, Remote Desktop Protocol (RDP) exploits
- Notable ransomware families: LockBit, Conti, REvil, BlackCat
- Double extortion: Attackers exfiltrate data first, then encrypt it, threatening to publish it if ransom is not paid

Impact: Operational shutdown, financial loss, permanent data loss, reputational damage.

C. Insider Threats

Insider threats come from current or former employees, contractors, or partners who intentionally or unintentionally compromise security. SMEs are especially vulnerable because they often grant broad access rights without strict access controls.

- Malicious insiders: Disgruntled employees stealing or leaking data for personal gain
- Negligent insiders: Employees using weak passwords, sharing credentials, or falling for phishing
- Compromised insiders: Employees whose accounts have been hijacked by external attackers

Impact: Intellectual property theft, regulatory violations, financial fraud, system sabotage.

1.3 Additional Threats to Document

Threat	How It Works	Impact on SMEs
Weak Passwords	Default or simple passwords on routers, admin panels	Easy account takeover
Unpatched Software	Known vulnerabilities in outdated OS or apps exploited	Remote code execution, data theft
Third-Party Risk	Vendors with access to your systems get breached	Supply chain compromise
Social Engineering	Manipulating employees via phone or in-person	Unauthorized physical access, data theft
DDoS Attacks	Flooding servers with traffic to take services offline	Revenue loss, customer disruption

1.4 Research Sources to Reference

- NIST National Vulnerability Database (NVD): nvd.nist.gov
- CISA Alerts and Advisories: cisa.gov/alerts-advisories
- Verizon Data Breach Investigations Report (DBIR): Published annually
- IBM Cost of a Data Breach Report: Annual report with SME-specific statistics
- European Union Agency for Cybersecurity (ENISA) Threat Landscape

Step 2: Develop a Risk Assessment Model

2.1 Adopting the NIST Cybersecurity Framework (CSF)

The NIST Cybersecurity Framework is the internationally recognized standard for cybersecurity risk management. It provides a structured approach that even non-technical business owners can understand and implement. The framework is organized into five core functions:

Function	Core Question	What to Do
IDENTIFY	What do we have?	Inventory all assets: hardware, software, data, people, vendors. Map which systems hold sensitive information.
PROTECT	How do we defend it?	Implement safeguards: access controls, firewalls, encryption, employee training, software updates.
DETECT	How do we know if attacked?	Set up monitoring: antivirus alerts, login anomaly detection, intrusion detection systems (IDS).
RESPOND	What do we do when attacked?	Create an incident response plan: who to call, how to isolate affected systems, who communicates externally.
RECOVER	How do we get back to normal?	Maintain tested backups, define Recovery Time Objectives (RTO), document lessons learned.

2.2 Building the SME Risk Assessment Model

Apply the NIST framework specifically to SME contexts by following this four-phase process:

Phase 1 – Asset Inventory

List every asset in the business that could be at risk. Categorize them:

- Physical assets: Computers, servers, printers, mobile devices, networking equipment
- Digital assets: Customer databases, financial records, employee data, intellectual property, email systems
- Human assets: Employees with system access, vendors/contractors, administrators
- Process assets: Billing workflows, customer onboarding processes, IT change management

Phase 2 – Threat Mapping

For each asset category, identify which threats from Step 1 are most relevant. Create a mapping matrix showing which threats target which assets (e.g., phishing primarily targets human assets; ransomware targets digital assets stored on servers).

Phase 3 – Vulnerability Assessment

Identify existing weaknesses in the business's defenses that make the threats more likely to succeed:

- No MFA on email accounts
- Outdated Windows/software with unpatched vulnerabilities

- No employee cybersecurity training in the past 12 months
- No offsite or cloud backups
- Flat network with no segmentation

Phase 4 – Risk Calculation

For each threat-vulnerability pair, calculate a risk score using the formula:

Risk Score = Likelihood (1–5) × Impact (1–5) = Score (1–25)

Step 3: Create a Risk Evaluation Metric

3.1 Likelihood and Impact Scales

Define clear, objective criteria for scoring likelihood and impact so the model is consistent and repeatable:

Score	Level	Likelihood Definition	Impact Definition
1	Very Low	Attack almost never occurs for this type of SME	Negligible effect; no disruption to operations
2	Low	Rare occurrences; requires significant attacker effort	Minor disruption; resolved quickly without financial loss
3	Medium	Occurs occasionally; moderate attacker capability needed	Moderate disruption; some financial loss or data exposure
4	High	Occurs frequently; low effort for attacker	Significant disruption; major financial loss or breach
5	Critical	Very common; automated attacks at scale	Catastrophic; business closure, regulatory fines, litigation

3.2 Risk Matrix (5×5 Grid)

The risk matrix below visualizes the combined risk level. Each cell shows the risk score (Likelihood × Impact) and is color-coded by severity:

L \ I →	Impact 1 (Negligible)	Impact 2 (Minor)	Impact 3 (Moderate)	Impact 4 (Major)	Impact 5 (Critical)
Likelihood 5	5 — Medium	10 — Medium	15 — High	20 — High	25 — Critical
Likelihood 4	4 — Low	8 — Medium	12 — Medium	16 — High	20 — High
Likelihood 3	3 — Low	6 — Medium	9 — Medium	12 — Medium	15 — High
Likelihood 2	2 — Very Low	4 — Low	6 — Medium	8 — Medium	10 — Medium
Likelihood 1	1 — Very Low	2 — Very Low	3 — Low	4 — Low	5 — Medium

3.3 Threat Risk Scoring for SMEs

Threat	Likelihood (1-5)	Impact (1-5)	Risk Score	Priority Level
Phishing / BEC	5	4	**20 — HIGH**	Immediate action required
Ransomware	4	5	**20 — HIGH**	Immediate action required
Malicious Insider	3	4	**12 — MED**	Address within 30 days
Unpatched Software	4	3	**12 — MED**	Address within 30 days
Third-Party Vendor Risk	3	3	**9 — MED**	Address within 60 days
Weak Password Policy	4	2	**8 — MED**	Address within 60 days
DDoS Attack	2	3	**6 — LOW**	Monitor and review quarterly

Step 4: Propose Risk Mitigation Strategies

4.1 Mitigation for Phishing and Business Email Compromise

Technical Controls

- Enable email authentication protocols: SPF, DKIM, and DMARC on your domain
- Deploy anti-phishing filters on email gateways (Microsoft Defender, Proofpoint, or Mimecast)
- Implement Multi-Factor Authentication (MFA) on all email accounts — even if a password is stolen, attackers cannot log in without the second factor
- Use email banners that flag external emails to alert employees automatically

Administrative Controls

- Conduct quarterly phishing simulations using free tools like GoPhish
- Create a written policy requiring verbal confirmation for any financial transfers over a set threshold
- Establish a clear reporting process so employees can flag suspicious emails without fear

4.2 Mitigation for Ransomware

Technical Controls

- Implement the 3-2-1 backup rule: 3 copies of data, on 2 different media, with 1 stored offsite or in cloud (e.g., AWS S3, Azure Blob Storage, Backblaze)
- Test backups monthly — a backup that has never been restored is not a real backup
- Disable Remote Desktop Protocol (RDP) or restrict it to VPN-only access
- Deploy endpoint detection and response (EDR) software such as CrowdStrike Falcon, Microsoft Defender for Endpoint, or Malwarebytes
- Enforce application whitelisting — only approved software can execute

Administrative Controls

- Create and practice an Incident Response Plan (IRP) specific to ransomware — define who to call, how to isolate systems, and when to involve law enforcement
- Maintain a contact list for your internet service provider, cyber insurance company, and a forensics firm
- Establish a 'never pay' or 'evaluate first' ransomware policy in writing

4.3 Mitigation for Insider Threats

Technical Controls

- Implement Principle of Least Privilege (PoLP): every employee gets only the minimum access needed for their specific job role
- Enable User Activity Monitoring (UAM) tools for employees with access to sensitive data
- Set up Data Loss Prevention (DLP) policies that alert when large amounts of data are copied or emailed externally
- Maintain detailed audit logs of who accessed what files and when

Administrative Controls

- Conduct background checks on new hires, especially those with access to financial systems or customer data

- Implement an off-boarding checklist that immediately revokes all access on an employee's last day
- Create a confidential whistleblower channel so employees can report suspicious behavior from colleagues

4.4 General Security Best Practices for All SMEs

Control Area	Recommended Action
Password Management	Require passwords of 14+ characters. Deploy a password manager (Bitwarden, 1Password) so employees never reuse passwords across accounts.
Software Patching	Enable automatic updates for OS and applications. Designate a monthly 'patch Tuesday' to verify all updates are applied.
Network Segmentation	Separate guest Wi-Fi from internal business network. Isolate point-of-sale systems and CCTV on their own VLANs.
Security Awareness Training	Mandatory cybersecurity training for all employees at onboarding and annually. Topics: phishing, password hygiene, physical security.
Firewall Configuration	Deploy next-generation firewalls (NGFWs). Block outbound traffic to known malicious IPs. Review firewall rules quarterly.
Cyber Insurance	Obtain a cyber liability insurance policy. Ensure it covers ransomware, data breach notification costs, and business interruption.

Step 5: Validate the Model with Case Studies

5.1 Case Study 1 — Retail Business Phishing Attack

Scenario

A regional clothing retailer with 45 employees received a spear-phishing email appearing to be from their logistics vendor. An accounts payable employee clicked the link, entered their credentials on a fake login page, and the attacker gained access to the company's accounting system. The attacker then redirected two vendor payments totaling $87,000 to a fraudulent bank account before the fraud was discovered three days later.

Applying the Risk Model

- Threat: Phishing / Business Email Compromise
- Likelihood Score: 5 (email is sent to all staff; vendor spoofing is trivial to set up)
- Impact Score: 4 (major financial loss but business survived)
- Calculated Risk Score: 20 — HIGH — correctly flagged as immediate priority

What Was Missing

- No MFA on email accounts — the stolen password alone was sufficient for access
- No employee phishing awareness training had been conducted in over two years
- No financial transfer verification policy requiring a callback to confirm bank changes

Model Validation Result

The model correctly identified BEC as a HIGH risk and the recommended controls (MFA, training, financial verification policy) would have prevented this incident. Validation: PASSED.

5.2 Case Study 2 — Healthcare Clinic Ransomware Attack

Scenario

A small dental clinic with 12 employees ran an unpatched version of Windows 10 with Remote Desktop Protocol enabled for remote access by their IT support vendor. Attackers found the exposed RDP port using automated scanning tools, brute-forced the weak password 'clinic2019', and deployed LockBit ransomware. All patient records, appointment schedules, and billing data were encrypted. The clinic paid $15,000 in ransom but still lost 3 days of operations and faced patient complaints about data exposure.

Applying the Risk Model

- Threats: Ransomware (primary), Unpatched Software (contributing), Weak Password (contributing)
- Ransomware Likelihood: 4, Impact: 5 — Score: 20 — HIGH
- Unpatched Software Likelihood: 4, Impact: 3 — Score: 12 — MEDIUM
- Weak Password Likelihood: 4, Impact: 2 — Score: 8 — MEDIUM

What Was Missing

- RDP was internet-facing rather than restricted to VPN-only
- No tested backup system — the clinic had an external hard drive but had never verified it could restore data
- No lockout policy on RDP — unlimited password attempts allowed brute force to succeed

Model Validation Result

The model correctly flagged ransomware as HIGH and both contributing vulnerabilities as MEDIUM. All three recommended controls would have either prevented the attack or significantly reduced its impact. Validation: PASSED.

5.3 Case Study 3 — Accounting Firm Insider Data Theft

Scenario

A mid-size accounting firm discovered that a departing senior accountant had copied over 3,000 client records to a personal USB drive one week before their resignation. The employee had access to the complete client database, which was not restricted by role. The firm faced regulatory investigation and potential GDPR fines due to improper handling of personal financial data.

Applying the Risk Model

- Threat: Malicious Insider
- Likelihood Score: 3, Impact Score: 4 — Score: 12 — MEDIUM

What Was Missing

- No Principle of Least Privilege — a senior accountant had access to all 3,000+ clients including those not assigned to them
- No USB port control policy or DLP software to detect/block large file copy operations
- No off-boarding checklist that would have triggered early revocation of access upon resignation notice

Model Validation Result

The model correctly rated malicious insider risk as MEDIUM-HIGH. All recommended controls (PoLP, DLP, off-boarding checklist, audit logging) would have either prevented or detected this theft before resignation. Validation: PASSED.

Step 6: Document Findings and Best Practices

6.1 Summary of Findings

Based on the risk assessment model, threat research, and case study validation, the following key findings apply to SMEs across industries:

1. Phishing and ransomware represent the highest risk to SMEs, combining high likelihood with severe business impact. They must be treated as immediate priority threats regardless of business size or industry.
2. Most successful cyberattacks against SMEs exploit well-known, preventable vulnerabilities: absence of MFA, unpatched software, and lack of employee training. These are not sophisticated zero-day attacks.
3. The financial and reputational consequences of a breach are disproportionately severe for SMEs — many cannot recover from a major incident without adequate preparation.
4. The NIST Cybersecurity Framework provides an accessible, scalable foundation for SME risk management that does not require advanced technical knowledge to begin implementing.
5. Insider threats, while rated medium in likelihood, often go undetected the longest and can cause the most lasting damage to client trust and regulatory standing.

6.2 SME Cybersecurity Best Practices Checklist

The following checklist can be used by any SME as an immediate action plan. Items are organized by priority:

Immediate Priority (Complete Within 1 Month)

- **Enable Multi-Factor Authentication on all email accounts, VPNs, and admin portals**
- **Implement a verified backup system following the 3-2-1 rule and test restoration**
- **Change all default passwords on routers, firewalls, and admin accounts**
- **Disable or VPN-restrict Remote Desktop Protocol (RDP)**
- **Apply all pending operating system and software security patches**

High Priority (Complete Within 3 Months)

- Conduct mandatory cybersecurity awareness training for all employees
- Run a phishing simulation to measure and improve employee response
- Implement Principle of Least Privilege — review and restrict all user access rights
- Deploy endpoint protection (antivirus/EDR) on all company devices
- Create a written Incident Response Plan with defined roles and contacts

Ongoing Practices (Quarterly and Annual)

- Perform quarterly review of user access rights and remove unnecessary permissions
- Test backups by performing full or partial data restoration exercises
- Conduct an annual risk reassessment using this framework as new threats emerge
- Review and update the Incident Response Plan after any security incident
- Assess and audit third-party vendors' security practices annually

6.3 Conclusion

This cybersecurity risk assessment framework provides SMEs with a practical, evidence-based approach to identifying, evaluating, and mitigating their most significant security risks. By combining the NIST Cybersecurity Framework with a quantitative risk scoring model and validating it against real-world case studies, the framework offers both strategic guidance and actionable steps that organizations can implement regardless of their size or technical capability.

The three case studies demonstrate that the model accurately identifies high-risk threats and that its recommended controls, if implemented, would have either prevented the incidents or significantly reduced their impact. SMEs that adopt this framework and treat cybersecurity as an ongoing organizational discipline rather than a one-time IT task will be substantially better positioned to protect their operations, customers, and reputation in an increasingly hostile threat landscape.